



Политике, конфигурација и безбедносна видљивост

Експлицитна правила, контролисане промене и проверљив доказ

Проблем који решавамо

Безбедносна правила постају поуздана тек када су видљива, верзионисана и проверљива. Правило расуто кроз неколико метода није лако објаснити, прегледати нити променити без нежељених последица. Политика зато представља договорено правило, а конфигурација његову примену у конкретном окружењу.

ПРОБЛЕМ

Шта може поћи по злу

Безбедносна правила постају поуздана тек када су видљива, верзионисана и проверљива. Правило расуто кроз неколико метода није лако објаснити, прегледати нити променити без нежељених последица. Политика зато представља договорено правило, а конфигурација његову примену у конкретном окружењу.

ЗАШТО

Зашто је тема важна

Видљивост не служи само реаговању на инцидент. Она омогућава тиму да разуме одлуку система, прати одступање од очекиваног стања и повеже догађаје кроз различите слојеве апликације.

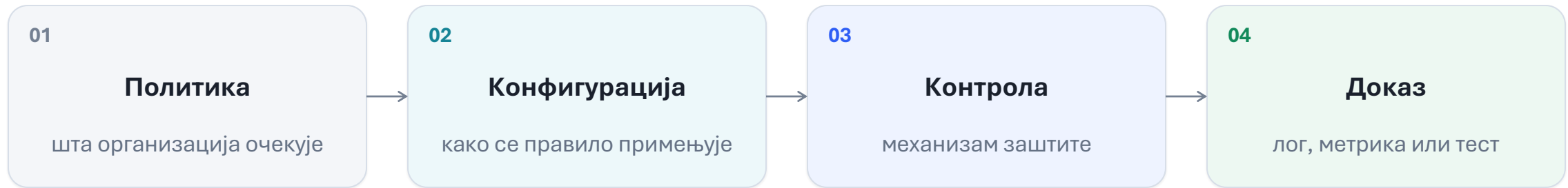
ИСХОД

Шта треба доказати

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.



КЉУЧНА ПОРУКА

Правило може бити добро написано, а контрола ипак неефективна. Доказ повезује очекивање са реалним понашањем.

Политика

шта организација очекује

01

**Нова верзија политике не брише
разлог због ког је стара одлука
некада била исправна.**

Питање: који улаз покреће ову одлуку?

02

**Политика описује намеру и важење,
док конфигурација чува вредности
којима се та намера примењује у
окружењу.**

Питање: која граница мора бити
видљива?

03

**Конфликт политика решава се
унапред договореним правилом,
често рестриктивнијом одлуком.**

Питање: који доказ остаје после
исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?

Конфигурација

како се правило примењује

01

Конфигурациона вредност има власника, значење и очекивани опсег.

Питање: који улаз покреће ову одлуку?

02

Свака промена која утиче на одлуку има власника, датум и јасан разлог.

Питање: која граница мора бити видљива?

03

Конфигурација не мења смисао политике без видљивог процеса одобравања.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?

Контрола

механизам заштите

01

Корелациони идентификатор повезује један безбедносни ток кроз слојеве система.

Питање: који улаз покреће ову одлуку?

02

Лог, метрика или тест дају доказ да систем ради према активном правилу, а не само да је правило записано.

Питање: која граница мора бити видљива?

03

Безбедносна контрола има власника и очекивани доказ, иначе нико не прати да ли је престала да ради.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?

Доказ

лог, метрика или тест

01

Конфликт политика решава се унапред договореним правилом, често рестриктивнијом одлуком.

Питање: који улаз покреће ову одлуку?

02

Конфигурација не мења смисао политике без видљивог процеса одобравања.

Питање: која граница мора бити видљива?

03

Безбедносна контрола има власника и очекивани доказ, иначе нико не прати да ли је престала да ради.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?

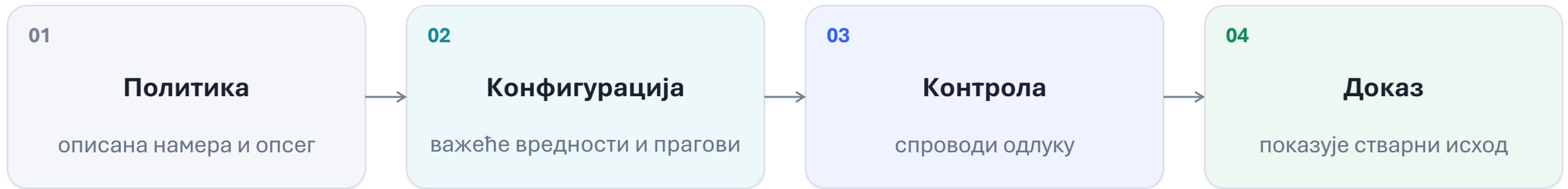
Политика, процедура и контрола

Поређење служи да се разлике виде без тешке табеле и ситног текста.

Елемент	Улога	Пример доказа
Политика	Одређује правило и циљ заштите.	Верзионисан текст са власником.
Процедура	Описује како људи или систем спроводе правило.	Преглед корака или аутоматизовани ток.
Контрола	Спречава, открива или ограничава ризик.	Тест, лог или резултат провере.
Метрика	Показује тренд или одступање.	Дефинисан праг и извор података.

Шема од правила до доказа

Правило може бити добро написано, а контрола ипак неефективна. Доказ повезује очекивање са реалним понашањем.



ЗАДАТАК

За сваки корак наведите ко га покреће, ко доноси одлуку и који траг остаје.

Како се бира безбедносна метрика

Од описа проблема до одлуке која може да се провери.

КОНТЕКСТ

Како се бира безбедносна метрика

Метрика је корисна само ако води ка одлуци. Зато се не почиње бројем, већ питањем које оператер или власник система мора да реши. Затим се бира извор, период посматрања и праг при коме је потребна акција.

01

Које понашање желимо да разумемо или ограничимо?

02

Који догађаји поуздано представљају то понашање?

03

Ко је власник прага и шта ради када се праг пређе?

04

Како разликујемо нормалну промену рада од безбедносног одступања?

Правило без доказа је само намера

Три правила која треба да остану видљива у имплементацији и ревизији.

01

Нова верзија политике не брише разлог због ког је стара одлука некада била исправна.

Јасно правило

02

Конфигурациона вредност има власника, значење и очекивани опсег.

Проверљива примена

03

Корелациони идентификатор повезује један безбедносни ток кроз слојеве система.

Видљив доказ

Како се ова тема види у развоју

Тема се види у малим одлукама током развоја, не само у завршној документацији.

РАЗВОЈНИ КОНТЕКСТ

Од принципа до радног кода

Тим бира неколико кључних одлука које мора моћи да објасни из лога и теста. То нису сви догађаји система, већ они чији би нејасан исход отежао истрагу, преглед приступа или корекцију конфигурације.

01

Именуј одлуку и њену границу.

02

Имплементирај проверу на серверу.

03

Додај позитиван и негативан доказ.

Пример: промена правила без губитка историје

Конкретан случај показује где опште правило постаје стварна одлука система.

СЦЕНАРИО

Пример: промена правила без губитка историје

Тим пооштрава правило за приступ административном интерфејсу. Ако старо правило само препише новим, касније не може да објасни зашто је ранији приступ био дозвољен нити да реконструише које је очекивање тада важило. Верзионисање не служи бирократији, већ очувању смисла историјских одлука.

01

Политика описује намеру и важење, док конфигурација чува вредности којима се та намера примењује у окружењу.

02

Свака промена која утиче на одлуку има власника, датум и јасан разлог.

03

Лог, метрика или тест дају доказ да систем ради према активном правилу, а не само да је правило записано.

Политика, конфигурација и контрола имају различите улоге

Код почиње од исте леве ивице као наслов прозора и остаје читљив на пројектору.

```
1 public Decision Evaluate(RequestContext ctx, Policy policy)
2 {
3     if (!policy.IsActiveAt(ctx.Now)) return Decision.Deny("inactive");
4     if (!policy.AppliesTo(ctx.AssetType)) return Decision.NotApplicable();
5     if (ctx.Config.Version != policy.RequiredBaseline)
6         return Decision.Deny("configuration_drift");
7     return policy.Rule(ctx) ? Decision.Allow() : Decision.Deny("rule");
8 }
```

ШТА ЈЕ ВАЖНО

Политика изражава намеру, конфигурација конкретно стање, а контрола производи експлицитан исход.

ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Drift мора бити видљив и проверљив

Негативан тест није споредан случај — он описује где право престаје.

```
1 [Fact]
2 public void Drift_from_required_baseline_is_visible()
3 {
4     var ctx = Context.WithBaseline("api-v3");
5     var policy = Policy.RequiresBaseline("api-v4");
6
7     var result = evaluator.Evaluate(ctx, policy);
8
9     result.Reason.Should().Be("configuration_drift");
10    metrics.DriftDetected.Should().Be(1);
11 }
```

ДОКАЗ

Тест не проверава само вредност, већ и разлог одбијања и сигнал који ће неко приметити.

ПРОВЕРА

Промените једну чињеницу и очекујте јасан, стабилан разлог одбијања.

Доказ мора да одговори шта се догодило

Чува се довољно контекста за реконструкцију, али не и тајне или непотребни лични подаци.

```
1 {  
2   "policyId": "data-export",  
3   "version": 4,  
4   "validFrom": "2026-10-01",  
5   "baseline": "api-v4",  
6   "decision": "denied",  
7   "reason": "configuration_drift"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна граница.

01

Уређивање објављене политике на месту без историје.

Нема јасног власника одлуке.

02

Тајне у конфигурационим датотекама или логовима.

Не постоји негативан сценарио.

03

Метрика без јасног питања на које треба да одговори.

Доказ не показује стварни исход.

Видљивост као способност тима

Добар доказ је свеж, поновљив и довољно јасан да га други члан тима протумачи.

ОБРАЗЛОЖЕЊЕ

Видљивост као способност тима

Обсервабилиту не значи чување сваког детаља заувек. Значи да се за важну одлуку може пронаћи довољно контекста: где је настала, кроз које слојеве је прошла и зашто је завршила успехом или одбијањем. Корелациони идентификатор даје заједничку нит том објашњењу.

01

Логови разликују технички траг од безбедносно значајног audit записа.

02

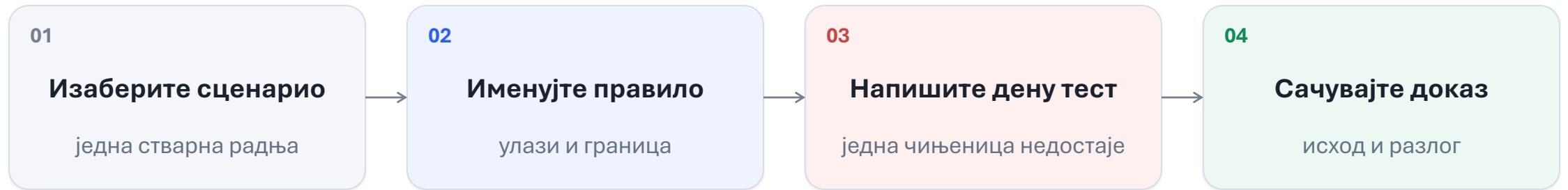
Метрика има име, власника и јасно питање које помаже да се одговори.

03

Тајне, токени и непотребни лични подаци не припадају ни логу ни метричкој ознаци.

Мини вежба за пројекат

На једном сценарију повежите одлуку, имплементацију, негативни тест и доказ.

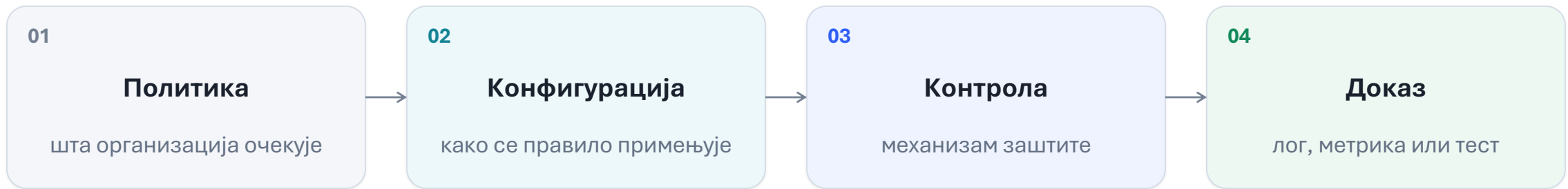


ЗАДАТАК ЗА ПРОЈЕКАТ

Примените тему „Политике, конфигурација и безбедносна видљивост“ на додељену пројектну целину и припремите доказ који други члан тима може да понови.

Провера разумевања

Тема је савладана када одлуку можете да објасните без ослањања на назив framework-a.



ЗА ЗАВРШЕТАК

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?

Следећи корак: применити исти модел на једну реалну границу у сопственом пројекту.